What is a baseline, and why does knowing what is normal matter for a SOC analyst?

1. hat is a baseline?

A baseline is a documented understanding of what normal activity looks like in an organization's IT environment.

It helps SOC analysts understand how users, computers, servers, applications, and networks normally behave.

In simple words:
A baseline is knowing what is normal so that you can identify what is abnormal.

For example:
Imagine an employee normally:

- Logs in between 9 AM and 6 PM.
- Uses one corporate laptop.
- Accesses email and business applications.
- Connects to a few internal servers.
- Transfers approximately 100 MB of data daily.

One day, the same employee:

- Logs in at 3 AM.
- Connects from an unfamiliar country.
- Attempts to access 50 internal servers.
- Downloads 20 GB of data.
- Executes PowerShell commands.

This activity differs significantly from the employee's normal behaviour.
A SOC analyst should investigate it.

2. Types of baselines

i. User behaviour baseline

Describes normal user activity.

Examples:

- Normal login times.
- Common login locations.
- Regularly accessed applications.
- Typical devices.
- Normal data access patterns.

Suspicious deviation:

An employee who normally logs in from Delhi suddenly authenticates from an unfamiliar country.

ii. Network baseline

Describes normal network communication.

Examples:

- Normal network bandwidth.
- Common internal connections.
- Standard DNS requests.
- Regular outbound connections.
- Typical network protocols.

Suspicious deviation:

A workstation that normally communicates with 10 internal servers suddenly communicates with 500 internal systems.

iii. Endpoint baseline

Describes normal endpoint behaviour.

Examples:

- Standard running processes.
- Installed applications.
- Approved services.
- Startup programs.
- Registry configurations.
- Security software status.

Suspicious deviation:

A new executable appears in a temporary directory and creates a persistent Windows service.

iv. Server baseline

Describes normal server activity.

Examples:

- Expected users.
- Normal CPU and memory usage.
- Common services.
- Regular connections.
- Standard administrative access.

Suspicious deviation:

A file server suddenly receives RDP connections from multiple employee workstations.

v. Authentication baseline

Describes normal authentication behaviour.

Examples:

- Normal number of successful logins.
- Expected failed login rate.
- Common logon types.
- Approved source IP addresses.
- Typical privileged account usage.

Suspicious deviation:
An administrator account generates hundreds of failed logon attempts from an unknown IP address.

3. Baseline examples for SOC analysts

Category	Normal behaviour	Suspicious deviation
User login	Login between 9 AM and 6 PM	Login at 3 AM without a valid reason
Network traffic	Regular business application traffic	Unexpected large outbound transfers
DNS	Requests to known business domains	Frequent queries to suspicious random domains
Processes	Chrome, Outlook, Teams	Word unexpectedly launches PowerShell
Services	Approved Windows services	Unknown service running from Temp
Registry	Known startup entries	Unexpected Run key modification
Authentication	Normal user logins	Repeated failed logins followed by success
SMB	Access to approved file servers	One workstation accesses dozens of servers
Privileges	Approved administrator accounts	Standard user added to Administrators
Remote access	RDP from approved VPN	RDP from an unknown external IP

4. Why is a baseline important?

There are five major reasons.

a. Detect anomalies

A baseline allows analysts to recognize activities that are different from normal behaviour.

b. Reduce false positives

Not every unusual event is malicious.
For example, an administrator may legitimately log in at midnight for maintenance.
Knowing the normal maintenance schedule helps analysts avoid unnecessary alerts.

c. Detect insider threats

An employee accessing files outside their normal responsibilities may indicate insider threats or compromised credentials.

d. Identify compromised accounts

If an account suddenly exhibits unusual login times, locations, devices, or resource access, it may be compromised.

e. Improve incident response

A baseline provides a reference point to determine:

- What changed?
- When did it change?
- Which system was affected?
- Which account performed the action?
- Was the activity authorized?

5. Practical SOC scenario: Detecting suspicious activity using a baseline

Consider the following situation.

Incident investigation example

Suspicious activity detected
User: john.doe
Device: OFFICE-PC-101

Normal baseline

- Login time: 9 AM–6 PM.
- Source: Corporate network.
- Common logon type: 2 and 3.
- Normal applications: Outlook, Chrome, Teams.
- Normal outbound traffic: 100 MB/day.

Observed activity

- Login time: 3:15 AM.
- Source: Unknown external IP.
- Logon type: 10.
- PowerShell launched unexpectedly.
- Outbound data transfer: 5 GB.

Baseline deviation

Potential security concerns

1. Compromised user credentials.
2. Unauthorized Remote Desktop access.

3. Suspicious PowerShell execution.
4. Potential data exfiltration.

How should the SOC analyst investigate?

Step	Investigation	Evidence
1	Check successful login	Event ID 4624
2	Identify failed attempts	Event ID 4625
3	Check logon type	Logon Type 10
4	Inspect process execution	Event ID 4688
5	Check privilege assignment	Event ID 4672
6	Investigate network traffic	Firewall logs and PCAP
7	Check DNS requests	DNS logs
8	Investigate data transfer	Proxy and network logs
9	Check for persistence	Registry and service changes
10	Correlate all evidence	SIEM timeline

The analyst should establish whether the login was legitimate, whether PowerShell execution was authorized, and whether data was transferred to an unauthorized destination.

If compromise is confirmed, the SOC team should follow its incident response procedures, which may include account containment, endpoint isolation, credential resets, and evidence preservation.